

JEWELBUG NATIVE MESSAGING HOST REGISTRATION

Source-observed Chrome native-messaging host used to bridge a malicious browser extension to a Windows command helper.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceRegistryEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

18 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceRegistryEvents

ATT&CK

T1176

Evidence-led dossier. Query status remains an untested implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Hunt the exact source-observed Registry path.

Symantec observed Antino writing the Chrome native-messaging host key `com.microsoft.runedge` as part of the malicious PDF Viewer extension chain. The path is directly observable in Defender XDR Registry telemetry.

OPERATIONAL VALUE

High-specificity campaign pivot, not durable behavior.

The exact key can reveal a browser-to-host command bridge before analysts depend on C2 domains or payload hashes. The attacker-controlled name is mutable, so the result remains Hunting rather than Production.

8.0

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- The malicious PDF Viewer extension used native messaging to reach a Windows helper.
- The helper ran operator commands through the Windows command interpreter.
- Symantec published the exact Chrome Registry key written by the chain.

ANALYTICAL ASSESSMENT

What the evidence supports

- The full Registry path is a precise retrospective pivot.
- A matching event requires manifest, helper and writer validation.
- The artifact does not establish attribution or successful command execution.

DETECTION ASSUMPTIONS

What must be validated

- MDE Registry telemetry is enabled and retained.
- RegistryKey preserves a comparable full path.
- The exact native-host name is not approved in the environment.

Confidence boundary

The source does not publish RegistryValueData, helper path, extension ID or command body. The native-host name can be changed trivially.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Watering hole

Injected webmail script delivers a fake update prompt.

02

Antino delivery

The downloaded installer deploys the Windows backdoor.

03

Extension sideload

PDF Viewer is added to the browser profile.

04

Native host

The helper is registered as com.microsoft.runedge.

05

Host commands

The extension can request Windows command execution.

Observable core

A Registry event touching the exact Chrome NativeMessagingHosts path for com.microsoft.runedge.

Non-observable boundary

Extension permissions, manifest contents, command body, successful shell execution, C2 response and data theft.

DETECTION HYPOTHESIS

The browser-to-host bridge should leave a Registry artifact.

If the attacker registers the source-observed helper, DeviceRegistryEvents should show a key under Chrome NativeMessagingHosts ending in com.microsoft.runedge. Software ownership, manifest/helper provenance, signer, writer process and follow-on activity distinguish legitimate use.

REQUIRED TELEMETRY

DeviceRegistryEvents

- Microsoft Defender for Endpoint Registry events.
- Complete RegistryKey value.
- Device and event identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- RegistryValueData and previous value.
- Writer path, command line, hash and account.
- Browser-extension, file, process and network telemetry.

UNAVAILABLE HERE

Do not infer

- Manifest or helper file contents.
- Browser API calls and command body.
- C2 success, theft or attribution.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR - DeviceRegistryEvents

Provides Registry creation/modification events plus device, value and initiating-process context.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

A matching key shows that the Registry path was touched; it does not prove the referenced helper is malicious or was invoked.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Registry event	DeviceRegistryEvents	Primary key-path evidence.	REQUIRED
Registry path	RegistryKey	Exact source-observed suffix.	REQUIRED
Event identity	Timestamp, ReportId	Unique-event investigation.	REQUIRED
Device	DeviceId, DeviceName	Endpoint pivot.	REQUIRED
Value	RegistryValueName, RegistryValueData	Manifest location enrichment.	OPTIONAL
Writer	InitiatingProcessFileName, InitiatingProcessCommandLine	Provenance and authorization.	OPTIONAL
Process key	InitiatingProcessUniqueId	Follow-on correlation.	OPTIONAL

Data quality requirements

- Confirm Registry event coverage and retention.
- Inspect path normalization in raw events.
- Preserve value data and referenced helper.
- Inventory approved native-messaging hosts.

Known failure conditions

- MDE is absent or Registry events are not retained.
- The actor changes the host name or browser path.
- RegistryKey is missing or truncated.
- The event predates retention.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find the documented browser-to-host bridge artifact.

Select Registry events whose key ends with the exact source-observed Chrome native-host path.

ANALYTICAL LOGIC

Direct filters and investigable output.

One direct, source-derived path filter; no ActionType assumption, value-data filter, join, sequence, threshold, rarity or aggregation.

KQL · UNTESTED HUNT

```
// Hunting query - Untested implementation sketch
// Primary platform: Microsoft Defender XDR / Advanced Hunting
// Required telemetry: Microsoft Defender for Endpoint registry events on Windows
// Evidence: Symantec observed Jewelbug writing the Chrome native-messaging host
// key HKCU\SOFTWARE\Google\Chrome\NativeMessagingHosts\com.microsoft.runedge.
// This exact campaign artifact is a triage lead, not attribution proof.
DeviceRegistryEvents
| where RegistryKey endswith @"\SOFTWARE\Google\Chrome\NativeMessagingHosts\com.microsoft.runedge"
| project
    Timestamp,
    DeviceId,
    DeviceName,
    ReportId,
    ActionType,
    RegistryKey,
    RegistryValueName,
    RegistryValueType,
    RegistryValueData,
    PreviousRegistryValueData,
    InitiatingProcessFileName,
    InitiatingProcessFolderPath,
    InitiatingProcessCommandLine,
    InitiatingProcessAccountName,
    InitiatingProcessSHA1,
    InitiatingProcessUniqueId
| order by Timestamp desc
```

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	DeviceName + Timestamp + ReportId	Manual triage

What a match means

The endpoint recorded activity against the exact campaign-specific native-messaging host path and requires immediate provenance review.

What a match does not prove

Malicious manifest/helper content, extension load, command execution, C2 activity, data theft or Jewelbug attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw event.
Verify key, value data, previous value, device and event identifiers.
- 02

Resolve the manifest.
Collect and parse the native-messaging manifest referenced by the default value.
- 03

Validate the helper.
Review path, hash, signer, publisher, prevalence and acquisition time.
- 04

Establish ownership.
Check browser-management policy, software owner and change record.
- 05

Review follow-on.
Inspect browser, command-shell, file and network activity on the same device.

Escalation gate

Escalate when the key is unauthorized and the manifest/helper is unsigned, newly staged, rare or followed by browser-originated command-shell or suspicious network activity.

Primary benign overlap

Enterprise browser integrations and security tests legitimately register native-messaging hosts. Exact name overlap is expected to be low but must be proven locally.

INVESTIGATION PIVOTS

Host
Role, owner, exposure and neighboring alerts.

Registry
Value data, previous value and adjacent native hosts.

Manifest
Allowed origins and helper path.

Helper
Hash, signer, publisher and prevalence.

Writer
Process ancestry, command line and account.

Follow-on
Browser child processes and outbound connections.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Approved browser integration	Legitimate products use native messaging to reach a local helper.	Require owner, publisher, hash, path and managed policy.
Software packaging test	Deployment tooling may create test keys.	Validate ticket, test window and package provenance.
Security lab reproduction	Analysts may reproduce the published artifact.	Scope to isolated assets and authorized exercises.

Baseline plan

- Run across all available retention.
- Inspect every raw match.
- Classify native-host owners and helper publishers.
- Measure value and writer-field completeness.

Validation procedure

- Replay a benign Registry creation in an isolated endpoint.
- Verify path normalization and case behavior.
- Confirm value data resolves to a manifest.
- Review historical matches and document approved owners.

TEST CASES

CASE	EXPECTED RESULT
Create a benign test native host	Expected Registry event with complete path and writer context.
Approved host with a different name	No match.
Create the exact name in an isolated lab	Expected match; collect value and writer fields.
Browser extension without native host	No match.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

Controlled replay matches, required fields are populated and historical matches are zero or fully attributable.

Rejection

The key is not collected or legitimate software frequently uses the exact name without separable context.

Failure

DeviceRegistryEvents is absent, incomplete or outside retention.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1176	Browser Extensions	Directly covers the source-observed malicious browser extension and its native-messaging bridge registration.

Detection coverage summary

Strong for the exact com.microsoft.runedge Chrome key; weak for renamed hosts, Firefox-only variants or memory-only browser manipulation.

Residual risk

The actor can change the host name, manifest path, extension ID and helper. Registry telemetry does not prove command execution or exfiltration.

ANALYST CONCLUSION

A precise hunt with an explicit campaign-artifact boundary.

Primary research and documented Defender fields support immediate retrospective hunting. Promotion requires controlled replay, native-host inventory and proof that manifest/helper provenance separates authorized integrations from malicious use.

REFERENCES

- Symantec and Carbon Black Threat Hunter Team, "Jewelbug: APT Group Runs Espionage and Crypto Fraud Operations Side by Side," 13 August 2026. <https://www.security.com/threat-intelligence/jewelbug-crypto-fraud-espionage>
- Microsoft Learn, "DeviceRegistryEvents table," accessed 18 August 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceregistryevents-table>
- MITRE ATT&CK, T1176. <https://attack.mitre.org/techniques/T1176/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	18 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.